

OAuth2 Best Practices

- JavaRush

Understand the basics

- Roles in OAuth2
 - Auth Server, Client, Resource / API Server, Resource Owner
- Interactions b/w roles
 - Authorization Request
 - Authorization Request Callback
 - Token Request
 - Client → Resource Server requests
- Security measures
 - State
 - Proof Key for Code Exchange (PKCE)

OAuth2 Grant Types

- Authorization Code Grant
 - Recommended for User involvement
- Implicit Grant
 - Used for Single Page Applications
 - Not recommended
- Client Credential Grant
 - Machine to Machine Communication
- Resource Owner Password Credential Grant
 - Avoid

PKCE

- Use Proof Key for Code Exchange
 - Highly recommended for Mobile and SPAs
 - Prevent Code Interception attack

Secure Redirect URI

- Exact Match Validation
- HTTPs
 - To secure data transmission

`https://myclientserver.com/oauth/callback` ✓

`https://*.myclientserver.com/oauth/callback` ✗

`http://myclientserver.com/oauth/callback` ✗

`https://myclientserver.com/oauth/callback/*` ✗

Tokens

- Short lived access tokens
- Refresh token
 - Store securely
 - Rotate frequently
- Revoke Tokens
 - Compromised tokens
 - Enable users to revoke tokens

Scopes & Least Privilege

- Least Privilege
 - Necessary scopes only
- Tell users about scopes

Client Secrets

- Store securely
 - Not in code (never)
- Different secrets for different environments
 - Development, Staging, Production

OAuth2 & OpenID Connect (OIDC)

- Understand the difference
- Authentication & Authorization

Multi Factor Authentication (MFA)

- Integrate MFA flow
 - Highly recommended for high-risk operations
 - Extra layer of security

OAuth2 Client

- Always use confidential client
 - If you can
- Public Client
 - Single Page Applications / Mobile Devices
 - Don't use client secret
 - Try to serve using Backend - [watch videos here](#)
- Don't reinvent the wheel
 - Use secure and well tested libraries
 - [OAuth 2.0 Client :: Spring Security](#)
 - [angular-auth-oidc-client - npm](#)
 - [GitHub - openid/AppAuth-Android: Android client SDK for communicating with OAuth 2.0 and OpenID Connect providers.](#)

OAuth2 Resource Server / API Server

- Don't reinvent the wheel
 - [OAuth 2.0 Resource Server :: Spring Security](#)
 - Watch this - [Creating and Securing Resource Server](#)

OAuth2 Authorization Server

- Don't create your own
 - Google, Facebook, Github
 - Okta, Auth0
- Deploy your own
 - [Keycloak](#)
- Create your own
 - [Spring Authorization Server](#)
 - [Building OAuth2 Authorization Server using Spring Authorization Server](#)

Thank You